

Manual 28 — AI Privacy & Automated Decision Governance Controlled Implementation

Controlled English project source. This manual operationalizes governance and evidence controls; it does not provide legal advice and does not treat voluntary guidance as law. Jurisdiction-specific obligations must be validated for each deployment and use case.

01. Purpose, scope, and controlled-use boundary

****Source layer:**** NIST Privacy Framework 1.0, NIST AI RMF 1.0, internal governance, and applicable legal overlays.

****Applicability:**** AI-assisted, algorithmic, profiling, and automated decision systems that process personal or person-linked data or materially affect individuals.

****Owner:**** AI governance lead with privacy/legal, security, product, and business owners.

****Procedure:**** Define system scope, affected populations, decision role, personal-data use, legal jurisdictions, excluded uses, and controlled implementation objectives before deployment.

****Evidence:**** Approved scope record, system identifier, accountable owners, jurisdiction map, and release boundary.

****Review/test:**** Confirm scope matches production behavior and data flows.

****Remediation/reassessment:**** Correct scope gaps and reassess after material use, jurisdiction, model, or data changes.

02. Source hierarchy, jurisdiction, and change watch

****Source layer:**** Applicable law/regulation; regulator guidance; contracts; NIST PF/AI RMF; internal policy and standards.

****Applicability:**** Every system governed by this manual.

****Owner:**** Legal/privacy with AI governance and compliance.

****Procedure:**** Maintain a source register that distinguishes binding obligations from voluntary guidance and tracks draft or superseding material separately.

****Evidence:**** Source register, version/date, authority, applicability rationale, and change-watch log.

****Review/test:**** Verify source status immediately before candidate freeze and after material regulatory change.

****Remediation/reassessment:**** Update mappings and controls without retroactively treating drafts as binding.

03. AI/ADM system inventory and ownership

****Source layer:**** NIST inventory/accountability concepts and internal asset governance.

****Applicability:**** Production, pilot, embedded, purchased, API-based, and shadow AI/ADM uses.

****Owner:**** Business system owner and AI governance.

****Procedure:**** Maintain authoritative inventory entries for purpose, model/provider, data domains, decision role, environments, users, affected individuals, and accountable owners.

****Evidence:**** Inventory record, lifecycle state, business owner, technical owner, privacy owner, and review date.

****Review/test:**** Reconcile inventory against procurement, APIs, cloud accounts, model registries, and data platforms.

****Remediation/reassessment:**** Register untracked systems and escalate unauthorized uses.

04. Decision taxonomy and consequence classification

****Source layer:**** Internal risk taxonomy informed by NIST risk framing and applicable legal definitions.

****Applicability:**** Any system influencing a decision about an individual.

****Owner:**** Product/business owner with privacy/legal and AI risk.

****Procedure:**** Classify the system as assistive, recommendatory, automated, or consequential and document whether humans can meaningfully alter the outcome.

****Evidence:**** Decision taxonomy record, consequence rating, human-role description, and legal-definition crosswalk where applicable.

****Review/test:**** Test actual workflow behavior against the declared classification.

****Remediation/reassessment:**** Reclassify if automation, reliance, or consequence changes.

05. Data-flow and model-flow lineage

****Source layer:**** NIST privacy engineering/data governance guidance and internal architecture controls.

****Applicability:**** Training, evaluation, inference, enrichment, feedback, and decision data flows.

****Owner:**** Data architect/engineer with privacy and model owner.

****Procedure:**** Map sources, transformations, features, model calls, outputs, recipients, stores, transfers, and feedback loops.

****Evidence:**** Data-flow diagram, model-flow diagram, lineage records, interface inventory, and transfer map.

****Review/test:**** Trace representative records end to end.

****Remediation/reassessment:**** Correct undocumented flows and reassess after pipeline changes.

06. Purpose specification and use limitation

****Source layer:**** Privacy-governance principles, contracts, applicable legal requirements, and internal policy.

****Applicability:**** Personal-data collection, reuse, inference, and decision processing.

****Owner:**** Business owner with privacy/legal.

****Procedure:**** Record approved purposes, compatible uses, prohibited uses, secondary-use review triggers, and decision boundaries.

****Evidence:**** Purpose register, approved use cases, prohibited-use list, and exception approvals.

****Review/test:**** Compare actual features, prompts, analytics, and downstream uses with approved purposes.

****Remediation/reassessment:**** Stop or remediate incompatible use and reassess before expansion.

07. Training and evaluation data governance

****Source layer:**** NIST AI RMF, privacy/data governance controls, contracts, and applicable law.

****Applicability:**** Data used to train, fine-tune, evaluate, calibrate, or benchmark models.

****Owner:**** Model/data owner with privacy, security, and legal.

****Procedure:**** Document provenance, authorization, representativeness, sensitivity, retention, quality, exclusions, and allowed model uses.

****Evidence:**** Dataset cards, provenance records, licenses/contracts, quality tests, approvals, and deletion obligations.

****Review/test:**** Sample source records and verify permissions and declared uses.

****Remediation/reassessment:**** Remove or replace noncompliant data and retrain/retest where impact is material.

08. Sensitive and inferred-data governance

****Source layer:**** Applicable privacy/sector law, regulator guidance, and internal data classification.

****Applicability:**** Sensitive identifiers, health, finance, biometrics, precise location, children's data, protected traits where regulated, and sensitive inferences.

****Owner:**** Privacy/legal with data owner and AI governance.

****Procedure:**** Identify sensitive inputs and inferences, apply stronger access/minimization controls, and document jurisdiction-specific restrictions.

****Evidence:**** Sensitive-data register, inference inventory, access rules, masking controls, and applicability analysis.

****Review/test:**** Inspect model features and outputs for undeclared sensitive inferences.

****Remediation/reassessment:**** Suppress, restrict, or redesign processing and reassess legal basis and risk.

09. Privacy risk and harms assessment

****Source layer:**** NIST Privacy Framework/NIST privacy engineering and applicable assessment duties.

****Applicability:**** Systems that create material privacy, autonomy, economic, reputational, safety, or surveillance risks.

****Owner:**** Privacy risk owner with AI governance and business owner.

****Procedure:**** Identify affected individuals, harmful data actions, likelihood, severity, scale, reversibility, mitigations, and residual risk.

****Evidence:**** Privacy risk assessment, harm scenarios, treatment plan, residual-risk acceptance, and review date.

****Review/test:**** Challenge assumptions with representative scenarios and affected-population perspectives where practicable.

****Remediation/reassessment:**** Implement additional controls or stop use where residual risk exceeds tolerance.

10. DPIA and AI-impact-assessment interfaces

****Source layer:**** Applicable jurisdictional assessment requirements plus internal AI/privacy risk methods.

****Applicability:**** Uses meeting legal or internal thresholds for formal impact assessment.

****Owner:**** Privacy/legal and AI governance.

****Procedure:**** Determine whether a DPIA, AI impact assessment, algorithmic impact assessment, or equivalent review is required and avoid assuming one assessment satisfies another jurisdiction automatically.

****Evidence:**** Threshold analysis, completed assessments, approvals, consultation records, and residual-risk decisions.

****Review/test:**** Verify assessment scope covers actual system, data, people, and decision context.

****Remediation/reassessment:**** Reopen assessments after material model, purpose, population, data, or deployment changes.

11. Automated-decision applicability analysis

****Source layer:**** Jurisdiction-specific automated-decision/profiling law and regulator guidance.

****Applicability:**** Decisions made or materially influenced by automated processing.

****Owner:**** Legal/privacy with business process owner.

****Procedure:**** Determine applicable definitions, exclusions, consequence thresholds, notice, rights, human-review, testing, and documentation duties for each jurisdiction/use case.

****Evidence:**** Applicability matrix, legal review record, system classification, and control mapping.

****Review/test:**** Compare actual workflow automation and human discretion with the analysis.

****Remediation/reassessment:**** Update controls when automation or legal scope changes.

12. Profiling and personalization governance

****Source layer:**** Applicable privacy/consumer-protection rules and internal analytics governance.

****Applicability:**** Behavioral prediction, segmentation, ranking, recommendation, targeting, and personalization involving individuals.

****Owner:**** Product/business owner with privacy and data governance.

****Procedure:**** Document profiling purpose, inputs, inferred attributes, recipients, consequence level, opt-out/rights interfaces where applicable, and prohibited profiles.

****Evidence:**** Profiling register, feature list, audience definitions, rights mapping, and approvals.

****Review/test:**** Test for undeclared profiling and incompatible reuse.

****Remediation/reassessment:**** Restrict or redesign profiling and reassess notices and rights.

13. Transparency and notice architecture

****Source layer:**** Applicable transparency/notice duties, NIST transparency concepts, and internal communication standards.

****Applicability:**** Individuals materially interacting with or affected by AI/ADM systems.

****Owner:**** Product/business owner with privacy/legal and communications.

****Procedure:**** Provide layered notices that accurately describe system role, data use, decision context, material limitations, rights/options where applicable, and contact/escalation routes.

****Evidence:**** Approved notices, version history, delivery evidence, language/accessibility checks, and change log.

****Review/test:**** Compare notice claims with actual system behavior.

****Remediation/reassessment:**** Correct misleading, stale, or incomplete notices before continued use where material.

14. Explainability and reason-code governance

****Source layer:**** Applicable explanation/reason duties, NIST AI RMF transparency concepts, and internal model-risk standards.

****Applicability:**** Decisions requiring understandable rationale for users, reviewers, auditors, or affected individuals.

****Owner:**** Model owner with business, legal/privacy, and model-risk functions.

****Procedure:**** Define explanation audience, approved method, reason-code logic, fidelity requirements, limitations, and escalation for unexplainable outcomes.

****Evidence:**** Explanation specification, reason-code catalog, validation results, and sampled decision explanations.

****Review/test:**** Test explanation fidelity and consistency against actual decision drivers.

****Remediation/reassessment:**** Correct misleading explanations or restrict system use.

15. Contestability and appeal mechanisms

****Source layer:**** Applicable rights/consumer/employment/sector duties and internal fairness/governance policy.

****Applicability:**** Consequential or otherwise appealable outcomes.

****Owner:**** Business process owner with legal/privacy and customer/employee operations.

****Procedure:**** Provide a documented route to question, challenge, correct data, submit context, and obtain qualified review where required or adopted by policy.

****Evidence:**** Appeal procedure, intake records, outcome records, service levels, and reviewer qualifications.

****Review/test:**** Sample appeals for independence, timeliness, and meaningful reconsideration.

****Remediation/reassessment:**** Correct procedural failures and feed systemic issues into model/process improvement.

16. Human oversight and intervention design

****Source layer:**** NIST AI RMF, applicable AI/ADM duties, and internal control design.

****Applicability:**** Systems where humans supervise, approve, override, or review outcomes.

****Owner:**** Business process owner and AI governance.

****Procedure:**** Define authority, competence, information available to reviewers, override ability, workload limits, escalation, and protection against rubber-stamping.

****Evidence:**** RACI, reviewer instructions, training, override logs, escalation records, and workload metrics.

****Review/test:**** Observe representative decisions and measure actual override/review behavior.

****Remediation/reassessment:**** Redesign oversight where review is nominal or ineffective.

17. Consent, preference, and legal-basis interfaces

****Source layer:**** Applicable privacy law and internal preference-management controls.

****Applicability:**** Processing relying on consent, opt-in/opt-out choices, or other jurisdiction-specific legal bases.

****Owner:**** Privacy/legal with product and data owner.

****Procedure:**** Record applicable legal basis or permission model, propagate choices to relevant systems, support withdrawal where required, and keep consent separate from uses relying on another valid basis.

****Evidence:**** Legal-basis register, consent/preference state, notice version, propagation logs, and exception records.

****Review/test:**** Trace representative preference changes through downstream processing.

****Remediation/reassessment:**** Correct stale or conflicting preference states and cease unauthorized processing.

18. Data minimization and feature governance

****Source layer:**** Privacy minimization principles, applicable law, and model governance.

****Applicability:**** Input features, prompts, embeddings, context stores, logs, and decision attributes.

****Owner:**** Model/data owner with privacy and product.

****Procedure:**** Require documented necessity for each material personal-data feature and remove redundant, excessively granular, or unjustified data.

****Evidence:**** Feature register, necessity rationale, ablation/testing results where appropriate, and approved exceptions.

****Review/test:**** Periodically challenge feature necessity and sensitivity.

****Remediation/reassessment:**** Remove or transform unnecessary data and retest model performance/risk.

19. Retention, deletion, and model-memory controls

****Source layer:**** Applicable retention/deletion duties, records policy, and architecture controls.

****Applicability:**** Training data, prompts, chat histories, embeddings, vector stores, logs, cached context, outputs, and feedback data.

****Owner:**** Data owner with privacy, records, and platform owner.

****Procedure:**** Define retention schedules, legal holds, deletion propagation, model-memory boundaries, backup handling, and exceptions.

****Evidence:**** Retention schedule, deletion jobs, deletion verification, hold records, and exception approvals.

****Review/test:**** Test deletion end to end across primary and derived stores where technically feasible.

****Remediation/reassessment:**** Repair failed deletion paths and reassess architecture if deletion cannot be reliably executed.

20. De-identification, pseudonymization, and PETs

****Source layer:**** Privacy engineering guidance, applicable law, and internal security standards.

****Applicability:**** Uses relying on reduced identifiability or privacy-enhancing technologies.

****Owner:**** Privacy engineering/data security.

****Procedure:**** Select techniques proportionate to risk, document threat model and re-identification assumptions, and restrict linkage keys and reversal capability.

****Evidence:**** Technique specification, key controls, re-identification tests, privacy parameters, and approved use restrictions.

****Review/test:**** Reassess against new auxiliary data and attack methods.

****Remediation/reassessment:**** Strengthen transformation or stop claims of de-identification where risk is excessive.

21. Fairness and bias interfaces without false legal equivalence

****Source layer:**** NIST AI RMF, applicable anti-discrimination/sector law, and internal responsible-AI policy.

****Applicability:**** Systems whose outputs may differ materially across relevant groups or proxies.

****Owner:**** AI/model risk with legal and business owner.

****Procedure:**** Define context-appropriate fairness questions, protected/legal categories where applicable, proxy risks, performance slices, decision thresholds, and escalation criteria.

****Evidence:**** Fairness test plan, subgroup metrics, proxy analysis, legal applicability review, and remediation decisions.

****Review/test:**** Test for materially adverse disparities and measurement limitations.

****Remediation/reassessment:**** Adjust data, features, thresholds, process, or use case and retest.

22. Access, identity, and privileged administration

****Source layer:**** Security/IAM standards and privacy confidentiality requirements.

****Applicability:**** Model consoles, datasets, prompts, logs, feature stores, vector databases, labeling tools, and decision systems.

****Owner:**** Security/IAM and platform owner.

****Procedure:**** Apply least privilege, strong authentication, privileged-access controls, segregation, periodic review, and prompt revocation.

****Evidence:**** Access matrix, approvals, MFA/PAM records, review results, and termination logs.

****Review/test:**** Sample privileged and sensitive-data access paths.

****Remediation/reassessment:**** Revoke excess access and investigate unauthorized use.

23. Third-party models, APIs, and data providers

****Source layer:**** Contracts, vendor risk, privacy law, NIST AI RMF, and supply-chain controls.

****Applicability:**** External models, hosted APIs, data brokers, enrichment services, evaluators, and subprocessors.

****Owner:**** Procurement/vendor risk with AI governance, privacy, security, and business owner.

****Procedure:**** Assess data use, training reuse, retention, subprocessors, security, privacy, model change, incident duties, audit evidence, termination, and exit portability.

****Evidence:**** Due diligence, contract clauses, data-processing terms, model cards, security/privacy evidence, and exit plan.

****Review/test:**** Revalidate high-risk providers and material model/version changes.

****Remediation/reassessment:**** Restrict data, require contract/control changes, or exit provider.

24. Cross-border processing and deployment

****Source layer:**** Applicable transfer/localization rules, contracts, and privacy governance.

****Applicability:**** Data, model hosting, support, telemetry, or decision processing crossing relevant jurisdictions.

****Owner:**** Privacy/legal with cloud/platform owner.

****Procedure:**** Map transfer paths, applicable mechanisms/restrictions, support access, subprocessors, and regional deployment requirements without assuming one mechanism applies globally.

****Evidence:**** Transfer map, legal assessment, contractual mechanism, regional architecture, and subprocessor list.

****Review/test:**** Compare actual hosting/support telemetry with approved regions.

****Remediation/reassessment:**** Reconfigure routing/hosting or update legal mechanisms.

25. Logging, traceability, and decision records

****Source layer:**** NIST AI RMF traceability concepts, privacy accountability, and internal logging standards.

****Applicability:**** Material AI/ADM decisions and supporting system actions.

****Owner:**** Platform/model owner with security and business process owner.

****Procedure:**** Log system/model version, relevant inputs or references, decision/output, reason information where appropriate, human actions, overrides, and material policy state while minimizing unnecessary personal data.

****Evidence:**** Audit logs, decision record schema, retention settings, integrity controls, and access records.

****Review/test:**** Reconstruct sampled decisions from retained evidence.

****Remediation/reassessment:**** Repair logging gaps and adjust retention/minimization balance.

26. Monitoring for drift, privacy harm, and misuse

****Source layer:**** NIST AI RMF monitoring concepts and internal risk controls.

****Applicability:**** Production systems throughout operation.

****Owner:**** Model owner, AI risk, privacy, and operations.

****Procedure:**** Monitor data/model drift, output quality, complaint patterns, sensitive inference, policy violations, abuse, subgroup performance, and unexpected use.

****Evidence:**** Monitoring dashboards, alerts, thresholds, investigation records, and trend reports.

****Review/test:**** Validate alert coverage and sample resolved alerts.

****Remediation/reassessment:**** Tune, suspend, roll back, or redesign systems when thresholds are exceeded.

27. Incident, complaint, and rights-request coordination

****Source layer:**** Applicable privacy/incident/consumer rights duties and internal incident response.

****Applicability:**** Security/privacy events, harmful outputs, complaints, rights requests, and decision challenges.

****Owner:**** Incident/privacy operations with AI governance and business owner.

****Procedure:**** Route events to the correct security, privacy, legal, customer/employee, and AI response processes; preserve evidence and applicable deadlines.

****Evidence:**** Case records, triage decisions, notifications, rights responses, containment actions, and lessons learned.

****Review/test:**** Exercise representative AI/privacy incident scenarios.

****Remediation/reassessment:**** Correct routing, control, or model defects and reassess risk.

28. Change management and material-model updates

****Source layer:**** Internal change control, NIST AI RMF lifecycle governance, vendor controls, and applicable regulatory change duties.

****Applicability:**** Model/version, prompt, retrieval, feature, data, threshold, provider, purpose, or deployment changes.

****Owner:**** Product/model owner with AI governance and privacy/security.

****Procedure:**** Classify change materiality, identify impacted assessments/notices/contracts/tests, obtain approvals, and maintain rollback capability.

****Evidence:**** Change ticket, impact analysis, test results, approvals, release notes, and rollback plan.

****Review/test:**** Confirm production version matches approved release.

****Remediation/reassessment:**** Roll back unauthorized or inadequately assessed changes.

29. Metrics, KRIs/KPIs, and management reporting

****Source layer:**** Internal governance and NIST measurement concepts.

****Applicability:**** Portfolio and system-level governance.

****Owner:**** AI governance/privacy leadership.

****Procedure:**** Track inventory coverage, assessment completion, rights/appeal performance, incidents, drift, provider issues, control exceptions, overdue remediation, and material disparity/privacy-risk indicators.

****Evidence:**** Metric definitions, dashboards, trend reports, thresholds, and management actions.

****Review/test:**** Verify metric lineage and prevent misleading aggregation.

****Remediation/reassessment:**** Correct weak indicators and escalate sustained threshold breaches.

30. Assurance, testing, and evidence inspection

****Source layer:**** Internal audit/assurance methods, NIST AI RMF evaluation concepts, and applicable audit requirements.

****Applicability:**** High-risk systems and sampled portfolio controls.

****Owner:**** Independent assurance/audit with subject-matter support.

****Procedure:**** Test design and operating effectiveness using evidence inspection, sampling, technical tests, interviews, rights/appeal samples, and decision reconstruction.

****Evidence:**** Test plan, workpapers, findings, management responses, remediation evidence, and closure approval.

****Review/test:**** Require independence appropriate to risk and avoid self-attestation as sole evidence for material controls.

****Remediation/reassessment:**** Track findings to verified closure and retest material corrections.

31. Localization, accessibility, and controlled source management

****Source layer:**** Project release controls and applicable accessibility/communication obligations.

****Applicability:**** English, es-419, pt-BR controlled editions and publication artifacts.

****Owner:**** Documentation/release owner with privacy/legal terminology review as applicable.

****Procedure:**** Preserve source distinctions, chapter parity, decision terminology, legal qualifiers, accessibility structure, language metadata, and unofficial-translation notices.

****Evidence:**** Controlled source files, parity results, accessibility checks, terminology notes, and change history.

****Review/test:**** Compare chapter counts, headings, key legal qualifiers, and rendered output across locales.

****Remediation/reassessment:**** Correct localization or accessibility defects before candidate freeze.

32. Release, provenance, and implementation roadmap

****Source layer:**** Repository release policy and controlled-build procedures.

****Applicability:**** Final Manual 28 release and future revisions.

****Owner:**** Release owner with AI governance/privacy stakeholders.

****Procedure:**** Revalidate sources; freeze controlled sources; reproducibly build EN/es-419/pt-BR DOCX/PDF candidates; bind SHA-256 identities; perform deterministic package/accessibility/render QA; durably stage exact bytes; verify predecessor Manual 27 is published; then reconcile catalog and release registry.

****Evidence:**** Source-state record, workflow run/artifact identity, manifest, six hashes, QA evidence, staging commit, final exact-head checks, and merge record.

****Review/test:**** Fail closed on missing predecessor, changed binary, failed gate, unresolved material defect, or stale authoritative-source assumption.

****Remediation/reassessment:**** Regenerate only when a deterministic defect or material source/control change requires it; otherwise preserve exact reviewed bytes.